

Mock Enterprise Risk Assessment Report

Executive Summary

This mock assessment demonstrates a Governance, Risk, and Compliance (GRC) workflow for a fictional mid-sized organization. Risks were identified based on common cybersecurity and operational threats and evaluated using likelihood and business impact.

Methodology

The assessment follows a qualitative 5x5 risk matrix. Each risk is assigned a likelihood and impact score, current controls are documented, and mitigation activities are recommended. References include NIST Cybersecurity Framework, CIS Controls, and SOC 2 Trust Services Criteria.

Key Findings

- Excessive privileged access presents the highest risk.
- Delayed patching increases exposure to known vulnerabilities.
- Phishing remains a significant business threat requiring continuous awareness training.
- Vendor security reviews should be performed annually.
- Backup restoration testing should be conducted quarterly.

Recommendations

1. Enforce least privilege and quarterly access reviews.
2. Automate vulnerability and patch management.
3. Expand phishing simulations and security awareness training.
4. Formalize third-party risk management.
5. Test disaster recovery and business continuity plans annually.

Portfolio Note

This report was created as part of a cybersecurity GRC portfolio to demonstrate practical experience with enterprise risk management documentation.